Flag 9 of 18: Stolen Sensitive Document

OAuth Heist scenario · Cymbal Investments · Google SecOps SIEM

Question

Continuing to monitor the compromised employee cloud activity from the attacker proxy infrastructure, what sensitive internal document did the adversary locate and download?

Answer

Cymbal_Q3_Database_Architecture_and_Service_Accounts.pdf

Evidence

- Google Drive event `item_download` (log type `WORKSPACE_ACTIVITY`, product `drive`), 20:23:51Z, user `elena.rostova@cymbal-investments.com`.
- Source IP `23.234.119.110`, a Texas address on ASN 11878 (`tzulo inc.`), a hosting provider. Elena own IP is `10.240.12.65`, so the download came from attacker infrastructure.
- `target.resource.name` holds the file name. Drive object ID `1x9ZkQ7vM3P9s8kL`.
- A database architecture and service accounts document is high value: it maps the systems and names the accounts to attack next.

How it was found

Window: Oct 15 20:00 to Oct 19 00:00 UTC.

```
principal.namespace = "Cymbal"
AND metadata.log_type = "WORKSPACE_ACTIVITY"
AND principal.user.email_addresses = /elena.rostova/ nocase
AND metadata.product_event_type = /download|view|export/ nocase
```

The search returned a single download event.

Lesson

The attacker used a second proxy IP, not the one seen on the phishing POST. Expect several addresses on attacker infrastructure, and look for hosting-provider networks that differ from the user normal IP.

Next pivot

The document names service accounts. Look for a privileged service account logging on to the database server.